

Registro de Actividades de Tratamiento (RAT)

Inventario de qué datos personales trata el sistema, con qué finalidad, bajo qué base legal, quién accede y por cuánto tiempo se conservan. Documento exigido por la Ley 21.719 (y consistente con las obligaciones de custodia de la Ley 20.584 y de seguridad de la Ley 19.628) — issue #29 (T6.3), parte del plan de compliance derivado de la auditoría técnica y legal (14 jul 2026).

Este documento se deriva directamente del modelo de datos real (`backend/prisma/schema.prisma`) y de las decisiones ya implementadas en el código (versionado de consultas, ledger de consentimientos, bitácora de auditoría). Debe actualizarse cada vez que se agregue un modelo o un campo que trate datos personales.

Última revisión: 2026-10-06 (sincronizado con el código y con `schema.prisma` a esa fecha).

Responsable del tratamiento

Umbral - RCE, a través del sistema de gestión de fichas clínicas descrito en este repositorio.

Inventario de actividades de tratamiento

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
1	Ficha clínica	Patient	Identificación, RUT, contacto, contacto de emergencia, médico/psiquiatra tratante	Prestación del servicio psicológico	Consentimiento informado — purpose TREATMENT en PatientConsent	Terapeuta tratante (therapistId); único rol del sistema (enum Role { PROFESSIONAL }), sin ruta de acceso excepcional	15 años desde el cierre (Ley 20.584). Soft delete (deletedAt), nunca se borra físicamente
2	Consulta clínica	Consultation + ConsultationHistory	Motivo de consulta, intervención, acuerdos, próxima sesión	Registro obligatorio de cada sesión	Consentimiento TREATMENT ; versionado append-only (groupId , correctsId)	Terapeuta tratante; correcciones quedan en ConsultationHistory	Igual que ficha (15 años); ninguna versión se sobrescribe
3	Telemedicina	Consultation.sessionType = TELEMED , PatientDocument.type = TELEMED_AGREEMENT	Datos de la consulta + acuerdo de telemedicina firmado	Atención remota	Consentimiento específico — purpose TELEMEDICINE	Terapeuta tratante	Igual que ficha

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
4	Email transaccional (verificación de cuenta / reset de contraseña)	MailService vía Resend (backend/src/modules/mail/mail.service.ts)	Nombre y email del profesional (dato del usuario del sistema, no del paciente)	Verificar la cuenta y permitir recuperar el acceso	Necesidad contractual para operar la cuenta — no requiere consentimiento del paciente porque no trata sus datos	Resend (procesador, EE.UU.); nadie más — el link de verificación/reset no viaja a ningún otro tercero	El email en sí no se retiene por Umbral más allá del envío; el token asociado expira (30 min en el reset)
4b	Control de alta de cuenta (código de invitación)	InvitationCode (backend/src/modules/auth/)	Código de un solo uso + createdById / usedById (referencias al propio User , ya cubierto por la fila 4) — sin datos personales nuevos	Impedir que cualquiera con el link público se cree una cuenta de terapeuta sin control (issue #124)	Necesidad contractual para operar la cuenta, igual base que la fila 4 — no trata datos del paciente	El único email autorizado en INVITE_CREATOR_EMAIL (genera); el propio profesional que se registra (consume)	El código expira a los 7 días; una vez usado o expirado no se borra el registro (queda como evidencia de qué invitación originó qué cuenta)
5	Documentos adjuntos	PatientDocument (consentimiento informado, informes, otros)	Archivos/PDFs vinculados al paciente	Soporte de la ficha clínica	Consentimiento TREATMENT	Quien subió (uploadedBy) + terapeuta tratante	Igual que ficha. Un documento subido por error no se elimina: se anula con motivo obligatorio (voidedAt , voidedById , voidReason), sigue listado y descargable por custodia, y la anulación queda auditada como DOCUMENT_VOID . Si el documento sustentaba el consentimiento vigente y no queda otro del mismo tipo, se agrega un evento REVOKE al ledger PatientConsent (nunca se modifica ni borra un evento previo)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
6	Exportación de PDF de ficha	Servicio de reportes (acción <code>EXPORT_PDF</code> en <code>AuditLog</code>)	Ficha + historial clínico completo	Entrega al paciente o a fiscalización	Deriva del consentimiento <code>TREATMENT</code> ya otorgado	Quien exporta, queda auditado	Hereda la retención de 15 años (obligación de custodia impresa en el pie del PDF)
7	Bitácora de auditoría	<code>AuditLog</code>	Usuario, acción, recurso, IP, user agent, detalle	Trazabilidad y evidencia ante fiscalización	Obligación legal / interés legítimo — no requiere consentimiento del paciente	Terapeuta tratante (lectura); inserción automática por el sistema, tabla append-only	15 años , igual que la ficha que audita — el log solo tiene razón de ser mientras existe el dato que audita
8	Historial de cambios de ficha	<code>PatientHistory</code> (snapshot + diff)	Ficha completa antes/después de cada edición	Trazabilidad de modificaciones a datos clínicos	Deriva de <code>TREATMENT</code>	Quien edita (<code>changedBy</code>), auditoría	Igual que ficha
9	Archivos personales (biblioteca privada por usuario)	<code>SharedFile</code>	Plantillas, formularios, protocolos, libros: material de la propia práctica del profesional, no datos de pacientes. El nombre del modelo viene de una versión multi-profesional anterior; hoy <code>SharedFilesService</code> filtra por <code>uploadedById</code> , así que nada se comparte entre cuentas (comentario en <code>schema.prisma</code>)	Recursos de trabajo del propio profesional	No aplica (no es dato personal de paciente), salvo que el profesional suba por su cuenta un archivo con datos personales	Solo el profesional que subió el archivo	Sin retención legal específica: se conserva hasta que el profesional lo elimine

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
10	Backups	Workflow <code>.github/workflows/backup.yml</code> (fuera de Prisma; reemplaza a <code>backups/backup.sh</code> , pensado para una VM propia que ya no existe; <code>backup.sh</code> fue retirado en el issue #61)	Volcado cifrado (AES-256, <code>openssl</code>) de toda la base	Continuidad operativa / recuperación ante desastre	Obligación de seguridad (Ley 19.628 art. 11 bis)	Quien tenga las credenciales de Backblaze B2 y la frase de cifrado (gestor de contraseñas del terapeuta)	Sin rotación: se conserva todo, indefinidamente — a este volumen (~40 KB/backup diario) 15 años de historial completo ocupan ~230 MB, muy por debajo de los 10 GB gratis de B2, así que no hace falta distinguir "operativo" de "custodia legal" con políticas de borrado distintas (issue #8, cerrado 2026-08-03)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
11	Sincronización con Google Calendar (opcional, por terapeuta)	GoogleCalendarConnection, CalendarEventLink (backend/src/modules/calendar-integration/)	Iniciales del paciente + código corto no reversible (sha256 truncado sobre patient.id , sin clave), fecha/hora de la sesión, link de vuelta a Umbral. Nunca RUT, nombre completo, sessionType ni texto clínico. El refresh token OAuth del terapeuta se cifra AES-256-GCM (GOOGLE_TOKEN_ENCRYPTION_KEY , dedicada — no comparte clave con DocumentEncryptionService)	Que el terapeuta vea sus sesiones de Umbral en su propia agenda de Google, sin re-tepearlas	No es un dato del paciente identificable fuera de Umbral (contenido minimizado por diseño) — el terapeuta conecta voluntariamente su propia cuenta de Google (calendar.events , access_type=offline); pendiente de revisión legal si la base habilitante es la necesidad contractual de operar la cuenta del terapeuta (mismo criterio que el email transaccional de la fila 4) o si, por derivarse de metadata de una sesión clínica, requiere la misma base que las filas 1-9 (ver sección "Transferencia internacional de datos")	El terapeuta dueño de la conexión (su propio Google Calendar); Google LLC como procesador de los eventos minimizados	Mientras la conexión esté CONNECTED ; el evento y el mapeo (CalendarEventLink) se borran al eliminar la sesión/paciente o al desconectar; una revocación (invalid_grant) marca la conexión DISCONNECTED y detiene el envío sin reintentos

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
12	Recordatorios de sesión	Notification, ReminderDispatch (backend/src/modules/reminders/, backend/src/modules/notifications/)	Nombre del paciente + fecha/hora de la sesión, en el cuerpo del recordatorio (canal IN_APP y EMAIL, a lo más un envío por (groupId, sessionId, offsetKind, channel))	Recordarle al terapeuta sus próximas sesiones	Deriva del consentimiento TREATMENT ya otorgado — mismo dato de la ficha, en un canal adicional; el email vía Resend llega a la casilla del propio terapeuta, no del paciente (mismo criterio que la fila 4)	El terapeuta destinatario; Resend como procesador del canal email (misma evidencia que la fila 4)	ReminderDispatch no se borra (la unicidad evita reenvíos duplicados). La Notification in-app leída se purga diariamente a las 04:30 pasados 30 días (NotificationsPurgeService, NOTIFICATIONS_PURGE_ENABLED, NOTIFICATIONS_PURGE_RETENTION_DAYS); las no leídas no se purgan

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
13	Cobro en línea por sesión (opcional, por terapeuta)	Payment , PaymentAccount (backend/src/modules/payments/)	Nombre del paciente + email (para el link de pago y el aviso de cobro vencido), monto y fecha de la sesión (amount , dueDate). Del terapeuta: credenciales de su propia cuenta Flow (apiKey/secretKey, PaymentAccount.credentialEncryption), cifradas en reposo bajo PAYMENT_CREDENTIALS_ENCRYPTION_KEY , dedicada — mismo criterio que GOOGLE_TOKEN_ENCRYPTION_KEY / DOCUMENT_ENCRYPTION_KEY (sdd/payments-multigateway-redesign: cada terapeuta conecta su propia cuenta, ya no hay comercio integrador de Umbral). Nunca datos de tarjeta ni credenciales bancarias — el checkout hospedado corre íntegramente en Flow, Umbral nunca custodia el dinero ni ve el medio de pago	Cobrar automáticamente cada sesión al paciente, liquidando directo a la cuenta del terapeuta que la dictó	Necesidad contractual de operar el cobro de la sesión — el terapeuta conecta voluntariamente su propia cuenta de Flow; pendiente de revisión legal si el envío del email con el link de pago (MailService.sendPaymentLinkEmail) requiere su propia finalidad de consentimiento (ConsentPurpose) distinta de TREATMENT , dado que hoy no existe ese member en el schema (ver design.md, Open Questions)	El terapeuta dueño del cargo (su propia cuenta de Flow); Flow S.A. como procesador del checkout y la liquidación	Mientras el cargo exista (Payment , mismo ciclo de vida que la sesión que factura — ligado por groupId , nunca se borra al pagarse); la cuenta de pagos (PaymentAccount) persiste hasta que el terapeuta la desconecte

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
14	Auto-agenda pública de pacientes (sdd/patient-self-scheduling)	TherapistAvailability, AvailabilityBlockout, PublicHoliday, BookedSlot (infraestructura de horario/cupo — dato operativo del propio terapeuta, no dato personal de paciente, mismo criterio que la fila 9). Adicionalmente, Patient: la reserva pública crea o vincula un registro de esta tabla, que es donde entra el dato personal (mismas filas que la fila 1)	Dos flujos distintos: (a) la configuración del propio horario del terapeuta (día/hora, bloqueos, duración de sesión) — no es dato personal de un paciente; (b) para un paciente nuevo creado vía el formulario público: nombre completo, RUT, fecha de nacimiento y email — recolectados sin verificación de identidad manual por el terapeuta y sin pasar por el flujo de consentimiento informado (PatientConsent, purpose TREATMENT) que sí atraviesa un paciente creado por un terapeuta autenticado hoy. Esta diferencia es la brecha legalmente relevante de esta fila	Permitir que el paciente reserve su propia sesión sin intervención manual del terapeuta	Pendiente de revisión legal. Un paciente autocreado por este flujo público no ha pasado por la misma captura de consentimiento informado que la fila 1 — no está resuelto si corresponde que herede automáticamente el consentimiento TREATMENT (y en qué momento se entendería otorgado), si debe capturarse un consentimiento propio en el formulario público antes de crear la ficha, o si el terapeuta debe regularizarlo manualmente después. Este documento no toma posición sobre cuál de esas opciones es la correcta — solo deja constancia de que hoy no se captura consentimiento explícito en el formulario público	El terapeuta dueño del link (mismo que fila 1); el paciente que se autoagenda ingresa sus propios datos pero no tiene ninguna sesión ni cuenta en el sistema (sin autenticación, sin OTP)	Igual que la ficha (fila 1) una vez creado el Patient — 15 años, mismo criterio (Ley 20.584)

#	Actividad	Modelo(s) Prisma	Datos tratados	Finalidad	Base legal / consentimiento	Quién accede	Retención
15	Perfil público del terapeuta (público por diseño)	Campos <code>name</code> , <code>bio</code> , <code>specialty</code> , <code>website</code> , <code>slug</code> y avatar del modelo <code>User</code> , servidos por GET <code>/public/therapists/:therapistId/profile</code> (sin autenticación)	Nombre, bio corta, especialidad, sitio web opcional (URL <code>http / https</code>), foto de perfil y <code>slug</code> (identificador público derivado del nombre, que arma el link <code>/book/<slug></code> ; se regenera al cambiar el nombre) del propio terapeuta. No incluye email, teléfono ni identificadores internos; el sitio web es el canal de contacto que el terapeuta decide publicar. Ningún dato de pacientes	Que el paciente conozca al terapeuta y tenga un canal de contacto antes de reservar en su agenda pública	El terapeuta carga cada campo voluntariamente desde "Perfil" sabiendo que es público; todos son opcionales y se pueden vaciar (el sitio web con cadena vacía)	Cualquier persona con el link de agenda pública (público por diseño); no hay procesador adicional	Mientras el campo esté cargado; el terapeuta puede borrarlo en cualquier momento y deja de publicarse al instante

| 16 | Sesiones de login | `Session` (`backend/src/modules/auth/`) | `jwt` del token, usuario, fechas de creación/expiración/revocación, `ipAddress` y `userAgent` del dispositivo desde el que se inició sesión. Es dato del profesional, no del paciente | Poder revocar sesiones (`POST /auth/logout` , `/auth/logout-all` , cambio de contraseña) y rechazar tokens robados o vencidos | Necesidad contractual y obligación de seguridad (Ley 19.628 art. 11 bis) para operar la cuenta; no trata datos del paciente | El propio sistema (`JwtStrategy` valida cada request); no hay pantalla que liste las sesiones | Purga diaria a las 04:00 (`SessionPurgeService` , `SESSION_PURGE_ENABLED`) de las sesiones expiradas o revocadas hace más de 7 días | | 17 | Segundo factor (MFA) | `User.mfaSecret` , `User.lastUsedStep` , `MfaRecoveryCode` | Secreto TOTP del profesional, cifrado en reposo con AES-256-GCM bajo `MFA_SECRET_ENCRYPTION_KEY` (clave dedicada, distinta de las de documentos, Google y pagos); último paso TOTP usado (anti-reutilización); 10 códigos de recuperación almacenados solo como hash (`codeHash`) con marca de uso (`usedAt`). Dato del profesional, no del paciente | Autenticación reforzada obligatoria y recuperación de la cuenta sin intervención manual | Obligación de seguridad (Ley 19.628 art. 11 bis) y necesidad contractual para operar la cuenta | Solo el propio sistema; los códigos de recuperación no se pueden volver a ver después de mostrarse | Mientras exista la cuenta; al regenerar los códigos de recuperación, los anteriores se reemplazan | | 18 | Bloques ocupados del calendario de Google (opcional, solo si `CALENDAR_AVAILABILITY_OVERLAY_ENABLED=true`) | `CalendarBusyBlock` (`backend/src/modules/calendar-integration/calendar-busy.service.ts`) | Solo intervalos de tiempo (`startsAt` , `endsAt`) de los eventos ocupados del Google Calendar que el terapeuta ya conectó (fila 11). No se guardan títulos, descripciones, asistentes ni identificadores de eventos | Descontar esos horarios de la disponibilidad que ve el paciente en la agenda pública | Mismo criterio que la fila 11: el terapeuta conecta voluntariamente su cuenta de Google; **pendiente de revisión legal** junto con ella | El terapeuta dueño y el cálculo de disponibilidad; el paciente solo ve el horario resultante como libre u ocupado, sin detalle | Se reemplazan en cada sincronización (cron cada 30 minutos) | | 19 | Seguimiento de entrega y apertura de recordatorios por email | `ReminderDispatch` (`resendMessageId` , `deliveredAt` , `openedAt`) alimentado por `POST /webhooks/resend` (`backend/src/modules/webhooks/`) | Identificador del mensaje en Resend y marcas de tiempo de entrega y apertura del email de recordatorio. El email va a la casilla del terapeuta (fila 12); el seguimiento de apertura lo aporta Resend | Que el terapeuta sepa si su recordatorio fue entregado o abierto (badge en la lista de consultas) | Mismo criterio que las filas 4 y 12: dato operativo del profesional, sin consentimiento adicional del paciente | El terapeuta (badge en Consultas); el webhook solo acepta eventos con firma Svix válida (`RESEND_WEBHOOK_SECRET`) | Igual que `ReminderDispatch` (fila 12): no se borra | | 20 | Registro de errores (Sentry, opcional) | `backend/src/instrument.ts` y `frontend/src/utls/error-tracking.ts` (sin modelo Prisma) | Solo si se define `SENTRY_DSN` / `VITE_SENTRY_DSN` . Errores 500 y excepciones no controladas: tipo, mensaje y traza de la excepción. En el backend se redactan emails y RUT en mensajes y se descartan bodies, cookies, headers, query string y datos de breadcrumbs; en el frontend se descartan bodies, cookies y headers de la request (la redacción de emails y RUT del mensaje solo existe en el backend). `tracesSampleRate` en 0 (sin trazas de rendimiento) | Detectar y corregir fallas de producción | Interés legítimo en la seguridad y continuidad del servicio; el diseño busca que no viajen datos de pacientes, pero un mensaje de error podría incluir texto no previsto | El equipo de desarrollo con acceso al proyecto Sentry; Sentry como procesador (ver Transferencia internacional) | La define el plan del proyecto Sentry (por confirmar); Umbral no conserva copia propia |

Nota sobre la fila 1 (versiones previas de este documento): este RAT describía anteriormente roles `SUPERVISOR / COORDINATOR / ADMIN` y un modo de "acceso excepcional" con `AuditLog.overrideReason`, y una fila 4 de "Compartir con red de salud" (purpose `HEALTH_NETWORK`). Ninguno de los tres existe en el código: el schema colapsó a un único rol (enum `Role` del modelo `User` en `schema.prisma`), `AuditLog` solo tiene `detail` (no `overrideReason`, modelo `AuditLog`) y `ConsentPurpose` solo tiene `TREATMENT / TELEMEDICINE` (enum `ConsentPurpose`) — `HEALTH_NETWORK` se eliminó por migración (`20260802100000_remove_health_network_consent`, ver issue #71). Corregido issue #65.

Transferencia internacional de datos

Toda la tabla de arriba asume implícitamente que los datos se procesan en Chile, pero eso ya no es así:

- La base de datos primaria (**todas** las filas 1-9: fichas, consultas, documentos, auditoría, historial) vive en **Supabase, hospedado en São Paulo, Brasil**.
- La copia de backup (fila 10) vive en **Backblaze B2, hospedado en Estados Unidos** — mitigado parcialmente porque llega cifrada con AES-256 antes de subir, así que Backblaze nunca tiene acceso al contenido en claro (a diferencia de Supabase, que sí lo tiene por necesidad operativa: no se puede consultar/actualizar una ficha clínica sin que la base la lea en claro).
- Backblaze B2 no solo guarda el backup: también aloja, en buckets privados y separados entre sí, los avatares, los archivos personales (`shared-files`) y los documentos adjuntos de la ficha (fila 5, cifrados en la aplicación antes de subir). Todos están en Estados Unidos, en la misma región (`us-west-004`): consta en `render.yaml` para avatares y el responsable del proyecto confirmó que los demás buckets usan la misma (issue #177). Los documentos adjuntos son datos de salud, por lo que les aplica la misma discusión de base habilitante que al backup.
- El email transaccional (fila 4) se envía vía **Resend, hospedado en Estados Unidos** ("Company's primary processing operations take place in the United States") — pero a diferencia de las filas 1-9, acá el dato que transita es del **profesional que usa el sistema** (nombre, email), no del paciente. No es una transferencia de datos de salud, así que la base habilitante que aplica no es el consentimiento informado del paciente sino la necesidad contractual de operar la cuenta del profesional.
- La sincronización opcional con Google Calendar (fila 11) envía a la **Google Calendar API (Google LLC, Estados Unidos)** únicamente contenido ya minimizado: iniciales + código no reversible + fecha/hora + link de vuelta a Umbral. Igual que con Resend, el dato que sale es del **terapeuta** operando su propia cuenta de Google, no una identificación directa del paciente — pero al tratarse de metadata de una sesión clínica (fecha/hora de atención), no está resuelto si la Ley 21.719 lo trata igual que el email transaccional de la fila 4 o si, por derivarse de un dato de salud, requiere la misma base habilitante que las filas 1-9. Pendiente de revisión legal, igual que el resto de esta sección.
- El registro de errores opcional (fila 20) envía a **Sentry** los eventos de error ya depurados (sin bodies, cookies ni headers; con emails y RUT redactados en el backend). La región de procesamiento depende de la organización Sentry configurada y no está confirmada en este repositorio; tampoco se ha recopilado aún evidencia de su DPA en `docs/evidencia-compliance/`. Pendiente de confirmar.
- El cobro en línea por sesión (fila 13) se procesa vía **Flow, cuya infraestructura de checkout corre en AWS us-east-2 (Ohio, Estados Unidos)** — verificado por DNS/rangos IP de AWS, ver evidencia más abajo (issue #118) — pese a que la entidad contratante (Flow Pagos Chile SpA) está domiciliada en Chile. Igual que con Resend/Google, el dato que transita es del **paciente** (nombre, email, monto) pero no es dato clínico, así que la base habilitante en discusión no es el consentimiento informado de tratamiento sino la necesidad contractual de operar el cobro de la sesión.

Esto constituye una transferencia internacional de datos de salud, que la Ley 21.719 regula explícitamente (requiere alguna base habilitante: nivel de protección adecuado del país destino, cláusulas contractuales con el proveedor, consentimiento explícito informado del paciente sobre dónde se almacenan sus datos, u otra excepción legal). **Esto no está resuelto ni evaluado legalmente** — determinar si la configuración actual (Supabase Brasil + Backblaze EE.UU.) cumple la Ley 21.719, y qué hace falta si no cumple (cláusulas contractuales, ajustar el texto del consentimiento informado, u otra medida), requiere revisión de alguien con conocimiento legal real, no es una decisión de ingeniería. Hasta que se resuelva, este punto queda documentado acá como riesgo abierto y conocido, no como algo ya evaluado y aceptado.

Evidencia recopilada hasta ahora (issue #55), guardada en `docs/evidencia-compliance/` (snapshots en PDF, con fecha, de páginas públicas que los proveedores pueden actualizar):

- **Supabase:** `supabase-dpa-2026-08-03.pdf` — el DPA se incorpora automáticamente al aceptar los Términos de Servicio (cláusula 12.2: "*acceptance of the Agreement shall have the same effect as signing the SCCs*"), sin firma separada. Confirmado por fuente oficial.
- **Backblaze:** `backblaze-dpa-eea-eu-2026-08-03.pdf` + `backblaze-tos-2026-08-03.pdf` — mismo mecanismo de incorporación automática, pero el DPA público encontrado está textualmente acotado a "*when GDPR applies*" (UE/EEA). No confirma por sí solo que aplique a una transferencia desde Chile. Pendiente: respuesta de `privacy@backblaze.com` sobre si combinan su DPA/SCCs con las Cláusulas Contractuales Modelo (CCM) que el Ministerio de Economía de Chile aprobó en diciembre 2025 (Resolución RAEX202503748) para transferencias bajo la Ley 21.719 -- ojo que la validez de esa aprobación ministerial también está en debate legal (¿le correspondía a la futura Agencia de Protección de Datos Personales, no al Ministerio?).
- **Resend:** `resend-dpa-2026-08-04.pdf` — mismo mecanismo de incorporación automática del DPA al aceptar los Términos de Servicio (`resend.com/legal/dpa`). Procesamiento primario en Estados Unidos; lista de subprocesadores en `resend.com/legal/subprocessors`. El alcance del DPA es amplio (EU SCCs/GDPR, UK SCCs, Suiza FADP, CCPA) pero, igual que con Backblaze, no menciona Chile ni la Ley 21.719 explícitamente.
- **Google** (issue #117): `google-dpa-2026-09-21.pdf` — Cloud Data Processing Addendum oficial (versión es-419, descargado directo de `cloud.google.com/terms/data-processing-addendum`), que cubre Google Workspace/Cloud Identity según su Appendix 4 (Specific Products). **Ojo:** el DPA aplica a cuentas contratadas bajo un Acuerdo de Google Workspace/Cloud Identity — no está confirmado que rija sobre una cuenta de Google **personal/gratuita**, que es la que el terapeuta conecta hoy vía OAuth (`calendar.events`, fila 11). Sigue pendiente de revisión legal si el DPA aplica igual, o si una cuenta personal se rige solo por los Términos de Servicio generales de Google (sin DPA formal), y cuál base habilitante corresponde en ese caso.
- **Flow** (issue #118): `flow-privacidad-2026-09-21.pdf` (Política de Privacidad oficial, `flow.cl/docs/privacidad/`) + `flow-terminos-condiciones-2026-09-21.html` (snapshot íntegro de `web.flow.cl/es-cl/legal/` — Flow no publica sus Términos y Condiciones como PDF descargable, a diferencia de Supabase/Backblaze/Resend/Google, así que se capturó la página completa en vez de un PDF). Los T&C confirman que las entidades que operan en Chile (**Flow Pagos Chile SpA**, RUT 76.644.017-7, y **Flow Subadquirente**) están constituidas conforme a la legislación chilena, domiciliadas en Santiago, y que "el tratamiento de datos personales efectuado por las Entidades Flow domiciliadas en Chile se registrará por la normativa chilena vigente en materia de protección de datos". Pero **domicilio legal no es lo mismo que ubicación física del procesamiento** — y verificado por separado (2026-09-21), resulta ser lo contrario: los hosts que efectivamente usa la integración (`sandbox.flow.cl/api`, el `DEFAULT_API_BASE_URL` de `flow-gateway.client.ts`, y su equivalente de producción `www.flow.cl`) resuelven a IPs de **AWS EC2 en la región us-east-2 (Ohio, Estados Unidos)** — confirmado cruzando la resolución DNS contra `ip-ranges.amazonaws.com` (rangos IP oficiales publicados por AWS), y corroborado por la cookie `AWSALB / AWSALBCORS` que ambos hosts devuelven (firma de un Application Load Balancer de AWS). Esto es evidencia técnica directa, no una declaración oficial de Flow, pero es reproducible: cualquiera puede repetir la resolución DNS y el cruce contra los rangos de AWS. **Conclusión:** la fila 13 **sí** constituye una transferencia internacional de datos (mismo tratamiento que Supabase/Backblaze/Resend), pese a que la entidad contratante esté domiciliada en Chile.

Criterio del gate de consentimiento (issue #176)

El consentimiento informado (`PatientConsent`, purposes `TREATMENT / TELEMEDICINE`) se exige **antes de registrar datos clínicos**, no antes de crear la ficha administrativa del paciente. Criterio: la Ley 20.584 exige el consentimiento previo al inicio del tratamiento, y `recordConsent` necesita un `Patient` existente, por lo que exigirlo antes del alta sería circular.

- **Dónde se aplica:** `ConsultationsService.create()` y `correct()` rechazan con 403 si no hay consentimiento vigente; el chequeo corre dentro de la misma transacción que la escritura. Son los únicos endpoints de escritura sobre `Consultation` (`POST /consultations` y `PATCH /consultations/:id/correct`).
- **Qué no se gatea:** el alta y la edición de datos de identidad/contacto del `Patient`, y su historial de cambios (`PatientHistory`). No contienen notas clínicas.
- **Reserva pública:** `createFromPublicBooking()` crea una `Consultation` sin consentimiento previo. Es un agendamiento, no un inicio de tratamiento: nace con texto genérico (`Reserva pública en línea / Pendiente de definir por el terapeuta`) y ningún dato clínico. La `Consultation` es la entidad de la que dependen disponibilidad, Google Calendar, cobro y agenda, por lo que no se separó del agendamiento. Los datos clínicos solo pueden ingresar mediante `correct()`, que exige el consentimiento.

Esto es orientación técnica, no validación legal.

Pendientes conocidos

- **Transferencia internacional de datos** — ver sección de arriba. Es el pendiente más importante de este documento hoy. Incluye la sincronización opcional con Google Calendar (fila 11): la evidencia del DPA de Google ya se recopiló (issue #117, `google-dpa-2026-09-21.pdf`), pero sigue sin resolverse si aplica a una cuenta personal (no Workspace) del terapeuta, y si corresponde la base habilitante de dato de salud o la de cuenta de profesional. También incluye el cobro en línea por sesión (fila 13): ya se confirmó que Flow procesa en AWS us-east-2, Estados Unidos (issue #118) — falta la misma revisión legal de base habilitante que el resto de esta sección.
- **Firma electrónica avanzada** (filas 2 y 6, a futuro): la firma de cada consulta/corrección y el sello de tiempo en los PDF exportados dependen de elegir un proveedor acreditado por la Ley 19.799 — ver issues #24, #25, #26 (T5.1, T5.2, T5.3).
- **Consentimiento específico para el email de link de pago** (fila 13): a diferencia de las demás filas, el envío automático del link de pago al email del paciente (`sendPaymentLinkEmail`) no está gateado hoy por ningún `ConsentPurpose` propio — la implementación (`sdd/online-payment-integration`) deliberadamente no inventó un member nuevo del enum sin definición legal confirmada. Si legal determina que corresponde una finalidad separada de `TREATMENT`, agregar el member y el gate es un cambio aditivo que no altera ninguna otra decisión de este módulo.
- **Consentimiento para pacientes autocreados vía auto-agenda pública** (fila 14): a diferencia de un paciente creado por un terapeuta autenticado, un paciente autocreado desde el formulario público de reserva no pasa hoy por ninguna captura de consentimiento informado (`PatientConsent`, `purpose TREATMENT`). No está resuelto si corresponde capturar consentimiento en ese mismo formulario público, si debe entenderse otorgado de otra forma, o si queda como una regularización manual pendiente del terapeuta — requiere revisión de alguien con conocimiento legal real, mismo criterio que el resto de esta sección.

Mantenimiento de este documento

Actualizar esta tabla cuando:

- Se agregue un modelo o campo nuevo en `schema.prisma` que trate datos personales de pacientes o usuarios.
- Se agregue una nueva finalidad de consentimiento (`ConsentPurpose`).
- Se agregue o cambie un procesador externo (por ejemplo, un servicio de monitoreo de errores).
- Se revise el documento: actualizar la fecha de "Última revisión" al inicio, aunque no haya cambios.
- Cambie algún plazo de retención o se resuelva alguno de los pendientes listados arriba.